

MOHAMMED Fahad

SIO 1

08/01/2026

Introduction

Pour ce TP, on devait faire un audit de sécurité sur des mots de passe. Le but c'était de tester si les mots de passe de différents utilisateurs étaient solides ou pas. On a utilisé deux machines : une Windows 10 et un Kali Linux pour faire nos tests.

M. Brillat voulait qu'on teste la robustesse des mots de passe avec des outils qui existent vraiment et qui sont utilisés par les professionnels en cybersécurité.

Matériel utilisé

- Une machine virtuelle Windows 10
- Kali Linux en live (sur ISO)
- Outils : FGDUMP, John the Ripper, Ophcrack
- Un fichier de tables arc-en-ciel (vista_proba_free)

Étape 1 : Préparation de Windows 10

Création des comptes utilisateurs

D'abord j'ai dû créer 3 comptes sur Windows. J'ai ouvert la gestion de l'ordinateur et j'ai créé les comptes dans le groupe Administrateurs :

- **ENEDIS** avec le mot de passe : judo63
- **MSA** avec le mot de passe : aurillac15
- **CLIC** avec le mot de passe : Paris2024!

Ça m'a pris un peu de temps parce que je me suis trompé au début, j'avais mis les comptes en utilisateurs normaux au lieu d'administrateurs.

Désactivation des protections

Ensuite j'ai désactivé Windows Defender et le contrôle des applications. C'était nécessaire pour que FGDUMP puisse fonctionner sans être bloqué.

Extraction des hash

J'ai téléchargé FGDUMP et je l'ai lancé en tant qu'administrateur. Le programme a tourné quelques secondes et il a créé un fichier sur le bureau qui s'appelle **127.0.0.1.pwdump**.

Quand j'ai ouvert ce fichier avec Notepad++, j'ai vu les hash des mots de passe. Ça ressemble à ça :

ENEDIS:500:aad3b435b51404eeaad3b435b51404ee:8d3e5f9c2b1a4e6f7c8d9e0a1b2c3d4e:::

Le hash c'est en fait le mot de passe crypté. C'est ce qu'on va essayer de craquer.

Étape 2 : Configuration de Kali Linux

J'ai démarré Kali en mode live depuis l'ISO. Au début c'était un peu compliqué parce que le clavier était en QWERTY.

Configuration du clavier

J'ai tapé la commande :

```
setxkbmap fr
```

Après ça le clavier était en AZERTY, beaucoup plus simple pour taper les commandes.

Montage de la partition Windows

Il fallait accéder au fichier pwdump depuis Kali. J'ai d'abord utilisé `fdisk -l` pour voir les partitions disponibles. J'ai vu que Windows était sur `/dev/sda2`.

J'ai monté la partition avec :

```
sudo mount /dev/sda2 /mnt/windows
```

Ensuite j'ai pu accéder au fichier sur le bureau de l'administrateur Windows.

Étape 3 : Tests avec John the Ripper

John the Ripper c'est un outil qui essaie de retrouver les mots de passe à partir des hash. J'ai fait plusieurs types d'attaques.

Test 1 : Mode "single"

```
john --format=NT --single/mnt/windows/Users/Admin/Desktop/127.0.0.1.pwdump
```

Ce mode essaie de transformer le nom d'utilisateur. Par exemple il teste enedis, enedis1, enedis123, etc.

Résultat : Ça n'a rien trouvé. Les mots de passe n'étaient pas basés directement sur les noms d'utilisateur.

Test 2 : Dictionnaire par défaut

bash

```
john --format=NT --wordlist=/usr/share/john/password.lst  
/mnt/windows/Users/Admin/Desktop/127.0.0.1.pwdump
```

Là John utilise une petite liste de mots de passe courants.

Résultat : Toujours rien. Le dictionnaire par défaut est trop petit.

Test 3 : Rockyou

Avant de lancer l'attaque, j'ai dû décompresser le fichier rockyou :

```
sudo gunzip /usr/share/wordlists/rockyou.txt.gz
```

Ensuite j'ai lancé :

```
john --format=NT --wordlist=/usr/share/wordlists/rockyou.txt  
/mnt/windows/Users/Admin/Desktop/127.0.0.1.pwdump
```

Résultat : Bingo ! John a trouvé le mot de passe d'ENEDIS (judo63) en moins d'une minute. C'est parce que judo63 est dans le dictionnaire rockyou qui contient des millions de mots de passe courants.

Test 4 : Avec règles

```
john --format=NT --wordlist=/usr/share/wordlists/rockyou.txt --rules  
/mnt/windows/Users/Admin/Desktop/127.0.0.1.pwdump
```

Avec les règles, John fait des variations : il ajoute des chiffres, met des majuscules, etc.

Résultat : Il a trouvé le mot de passe de MSA (aurillac15) mais ça a pris environ 5 minutes.

Pour CLIC, John n'a rien trouvé même après 10 minutes. J'ai arrêté le test parce que ça prenait trop de temps.

Affichage des résultats

```
john --format=NT --show  
/mnt/windows/Users/Admin/Desktop/127.0.0.1.pwdump
```

Cette commande affiche tous les mots de passe que John a réussi à craquer.

Étape 4 : Tests avec Ophcrack

Ophcrack c'est un autre outil mais qui utilise des tables arc-en-ciel. C'est différent de John parce qu'au lieu de tester un par un les mots de passe, il utilise des tables précalculées.

Lancement d'Ophcrack

J'ai ouvert Ophcrack depuis le menu Applications → 05 - Password Attacks.

Chargement du fichier

J'ai cliqué sur "Load" puis "PWDUMP file" et j'ai sélectionné le fichier 127.0.0.1.pwdump.

Installation des tables

J'ai cliqué sur "Tables" puis "Install". J'ai sélectionné le fichier vista_proba_free.zip que j'avais décompressé avant sur Windows.

Résultats

Après avoir cliqué sur "Crack", Ophcrack a lancé l'attaque.

Résultat :

- ENEDIS : Trouvé en quelques secondes (judo63)
- MSA : Trouvé en 2-3 minutes (aurillac15)
- CLIC : Pas trouvé

Ophcrack a été plus rapide que John avec les règles, mais il n'a pas trouvé le mot de passe de CLIC non plus.

Résultats et analyse

Compte	Mot de passe	John (temps)	Ophcrack (temps)	Trouvé
ENEDIS	judo63	30 secondes	5 secondes	Oui
MSA	aurillac15	5 minutes	2 minutes	Oui
CLIC	Paris2024!	Non trouvé	Non trouvé	Non

Explications

ENEDIS (judo63) : C'était le plus facile à craquer parce que c'est un mot simple du dictionnaire avec des chiffres à la fin. Ce genre de mot de passe est très vulnérable.

MSA (aurillac15) : Un peu plus difficile parce que c'est un nom de ville mais ça reste dans les dictionnaires. Les outils ont quand même réussi à le trouver avec les variantes.

CLIC (Paris2024!) : Celui-là n'a pas été craqué. C'est parce qu'il mélange majuscule + chiffres + caractère spécial (!). En plus "Paris2024" n'est peut-être pas dans le dictionnaire rockyou ou alors la combinaison exacte n'a pas été testée.

D'accord ! Encore plus simple :

Ce que j'ai appris sur la sécurité

Après tous ces tests, j'ai compris plusieurs choses importantes.

La longueur compte beaucoup

Plus le mot de passe est long, plus c'est difficile à craquer. judo63 avec 6 caractères a été trouvé en 5 secondes. Paris2024! avec 10 caractères n'a pas été trouvé. Il faut minimum 12 caractères.

Il faut mélanger les caractères

Un bon mot de passe doit avoir des minuscules, des majuscules, des chiffres et des symboles (!@#\$). judo63 n'avait que des minuscules et des chiffres, c'est pour ça qu'il a été craqué vite. Paris2024! était plus fort parce qu'il avait une majuscule et un point d'exclamation.

Pas de mots du dictionnaire

Les outils ont des énormes listes de mots courants. Le mot "judo" et la ville "aurillac" sont dedans. Même avec des chiffres derrière, ça reste facile à trouver.

Éviter les trucs prévisibles

Les gens mettent souvent mot+123 ou mot+2024. Les outils testent automatiquement ça. C'est trop facile.

Un mot de passe par site

Si un mot de passe est craqué, tous les comptes avec ce mot de passe sont en danger. Il faut utiliser un mot de passe différent partout. On peut utiliser un gestionnaire de mots de passe pour retenir tout ça.

Activer le 2FA

Même si le mot de passe est trouvé, le 2FA demande un deuxième code. Ça protège vraiment bien.

CONCLUSION

Conclusion

Je pensais qu'un mot simple avec quelques chiffres suffisait. Mais j'ai vu qu'on peut craquer ça en quelques secondes avec des outils gratuits.

Le plus impressionnant c'est la vitesse. Ophcrack a trouvé judo63 en 5 secondes. Si j'ai pu faire ça en TP, un vrai pirate peut faire pire avec du bon matériel.

J'ai compris pourquoi les entreprises sont strictes sur les mots de passe. Si un compte admin est piraté, tout le système est en danger. Vol de données, virus, blocage du réseau, ça peut coûter très cher.

Le principal problème c'est que les gens ne savent pas que leur mot de passe est faible. Ils pensent que personne ne va les pirater. Mais les pirates utilisent des programmes qui testent des milliers de comptes automatiquement.

Pour finir, un bon mot de passe c'est : long (12 caractères minimum), complexe (majuscules + minuscules + chiffres + symboles), différent pour chaque site, et avec le 2FA si possible.